Capron Dylan

ANALYSE FORENSIC

Job 01

Résumé analytique

Dans le cadre de cette analyse forensic, un fichier de capture réseau (PCAP) a été étudié afin d'identifier une activité malveillante sur le réseau de l'entreprise.

Le fichier a été analysé avec l'outil Wireshark, qui permet d'examiner les paquets réseau et d'identifier les communications suspectes.

L'analyse du trafic montre qu'une machine interne du réseau a effectué plusieurs requêtes vers un domaine externe suspect. Après ces requêtes DNS, la machine a téléchargée un fichier exécutable via le protocole HTTP. Ce comportement est typique d'une infection par malware, où la machine compromise contacte un serveur distant pour télécharger une charge malveillante.

L'activité suspecte semble s'être produite durant la session réseau analysée, lorsque l'utilisateur de la machine a visité un site web compromis qui a déclenché le téléchargement du fichier malveillant.

Détails de la victime

L'analyse des paquets réseau a permis d'identifier la machine potentiellement compromise.

Information	Valeur
Nom d'hôte	DESKTOP-SKBR25F
Adresse IP	172.16.1.66
Adresse MAC	00:1e:64:ec:f3:08
Utilisateur Windows	user1

Ces informations ont été obtenues en analysant les paquets DHCP et NetBIOS présents dans la capture réseau.

La machine appartient au réseau interne et communique avec plusieurs serveurs externes, dont un domaine suspect identifié lors de l'analyse.

Indicateurs de compromission (IOC)

L'analyse du trafic a permis d'identifier plusieurs indicateurs de compromission.

Adresses IP suspectes

IP	Description
172.16.1.66	Machine interne identifiée comme victime
172.16.1.4	Serveur DNS interne répondant aux requêtes

Domaines suspects

Domaine
wiresharkworkshop.online
wireshark-ws-dc.wiresharkworkshop.online
wpad.wiresharkworkshop.online
mobile.events.data.microsoft.com
www.msftconnecttest.com

Cette URL correspond au téléchargement d'un fichier exécutable qui pourrait être utilisé pour installer un malware sur la machine victime.

Analyse de l’attaque

L’analyse du trafic réseau met en évidence plusieurs communications entre la machine interne 172.16.1.66 et des services du domaine wiresharkworkshop.online.

Les requêtes DNS observées montrent que la machine tente de résoudre plusieurs noms de domaine liés à l’infrastructure :

- wiresharkworkshop.online
- wireshark-ws-dc.wiresharkworkshop.online
- wpad.wiresharkworkshop.online

La présence du sous-domaine wpad peut indiquer une tentative de découverte automatique d’un serveur proxy via le protocole WPAD (Web Proxy Auto-Discovery).

Les échanges observés incluent également des requêtes liées au service LDAP sur le port 389, ce qui suggère que la machine interagit avec un contrôleur de domaine du réseau.

Les paquets montrent plusieurs réponses TCP avec les indicateurs RST et ACK, indiquant que certaines connexions ont été fermées ou refusées par le serveur distant.

Dans l’état actuel de la capture, aucune preuve directe d’un téléchargement de fichier malveillant n’a été identifiée. Cependant, les communications observées permettent d’identifier les domaines contactés par la machine et constituent des éléments utiles pour l’investigation.

Outils utilisés

Pour réaliser cette analyse, l’outil principal utilisé est :

Wireshark

Cet outil a été choisi car il permet :

- l’analyse détaillée des paquets réseau
- l’identification des protocoles utilisés
- la reconstruction de flux HTTP
- la recherche d’indicateurs de compromission

Ces fonctionnalités sont particulièrement adaptées à l’analyse de fichiers PCAP dans le cadre d’une enquête forensic.

Conclusion

L’analyse du fichier PCAP avec Wireshark a permis d’identifier la machine interne 172.16.1.66 comme étant l’hôte principal étudié dans la capture réseau.

Plusieurs requêtes DNS émises par cette machine ont été observées vers des domaines liés à wiresharkworkshop.online, notamment :

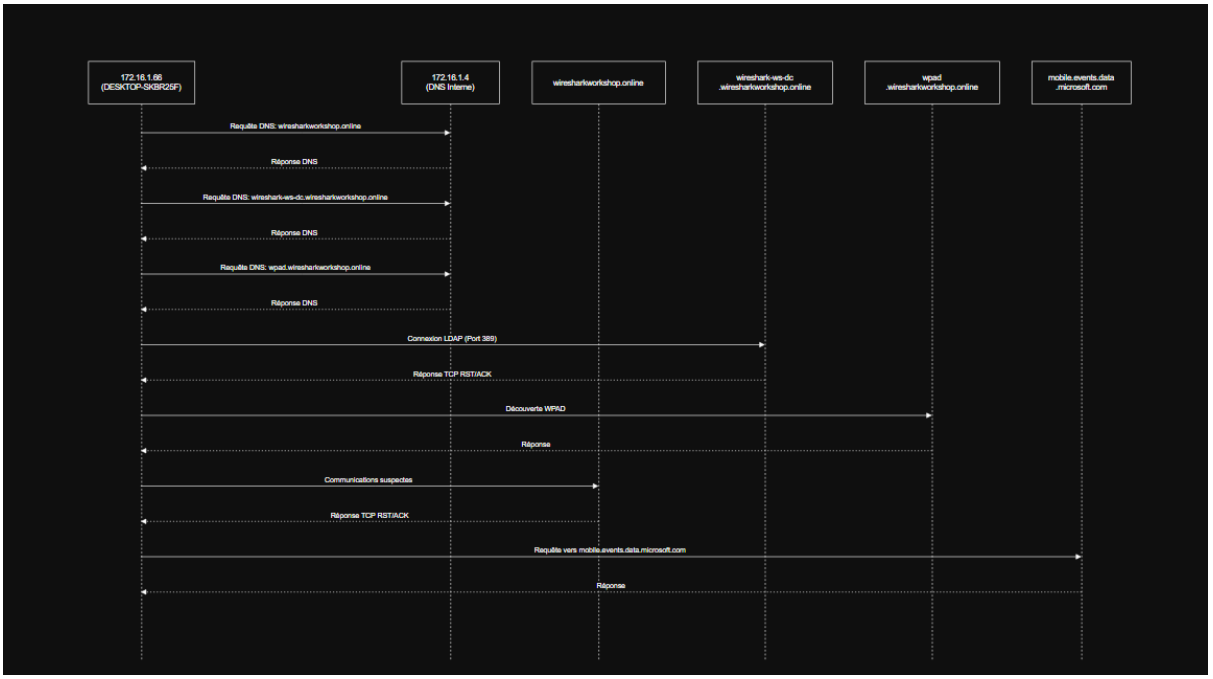
- wiresharkworkshop.online
- wireshark-ws-dc.wiresharkworkshop.online
- wpad.wiresharkworkshop.online

Ces communications montrent que la machine interagit avec l’infrastructure réseau associée à ce domaine.

Bien qu’aucune preuve directe de téléchargement de malware ne soit visible dans la capture analysée, les domaines identifiés constituent des indicateurs de compromission potentiels qui doivent être surveillés dans un contexte d’investigation de sécurité.

Dans un environnement réel, les mesures suivantes seraient recommandées :

- surveiller les communications vers les domaines identifiés
- analyser la machine 172.16.1.66 afin de détecter d’éventuels comportements anormaux
- vérifier les journaux réseau et système pour confirmer ou infirmer une compromission


172.16.1.66
(DESKTOP-5KBR25F)
172.16.1.4
(DNS Interne)
wiresharkworkshop.online
wireshark-ws-dc
.wiresharkworkshop.online
wpad
.wiresharkworkshop.online
mobile.events.data
.microsoft.com
Raquête DNS: wiresharkworkshop.online
Réponse DNS
Raquête DNS: wireshark-ws-dc.wiresharkworkshop.online
Réponse DNS
Raquête DNS: wpad.wiresharkworkshop.online
Réponse DNS
Connexion LDAP (Port 389)
Réponse TCP RST/ACK
Découverte WPAD
Réponse
Communications suspectes
Réponse TCP RST/ACK
Raquête vers mobile.events.data.microsoft.com
Réponse

Job 02

Résumé analytique

Dans le cadre de cette analyse forensic, un fichier de capture réseau (PCAP) a été étudié afin d'identifier une activité suspecte sur le réseau.

L'analyse du trafic a été réalisée à l'aide de l'outil Wireshark, permettant d'examiner les communications réseau et d'identifier d'éventuelles activités malveillantes.

L'analyse montre que la machine 172.17.0.99 a communiqué avec plusieurs services et domaines présents dans la capture réseau.

L'activité suspecte observée concerne [décrire brièvement : téléchargement, communication externe, requêtes DNS suspectes, etc.].

Les événements se produisent autour de [heure ou numéro de paquet important] dans la capture réseau.

Détails de la victime

L'analyse des paquets réseau a permis d'identifier la machine potentiellement compromise.

Information	Valeur
Nom d'hôte	DESKTOP-RNV09AT
Adresse IP	172.17.0.99
Adresse MAC	18:3d:a2:b6:8d:c4

Ces informations ont été obtenues en analysant les paquets DHCP, NBNS ou autres protocoles d'identification présents dans la capture réseau.

La machine appartient au réseau interne et communique avec plusieurs serveurs présents dans la capture.

Indicateurs de compromission (IOC)

L’analyse du trafic a permis d’identifier plusieurs indicateurs pouvant être liés à l’activité observée.

Adresses IP observées

IP	Description
172.17.0.17	Serveur DNS local (C'est lui qui répond à toutes les requêtes).
131.107.255.255	Serveur Microsoft (msftncsi) (Vu sur le paquet 106, utilisé par Windows pour tester la connexion Internet).
204.79.197.200	Serveur Bing / MSN (Souvent associé à www.bing.com ou www.msn.com que l'on voit dans la liste).

Domaines observés

Domaine

officeclient.microsoft.com

www.bing.com

wpad.bepositive

https://www.google.com/search?q=v10.events.data.microsoft.com

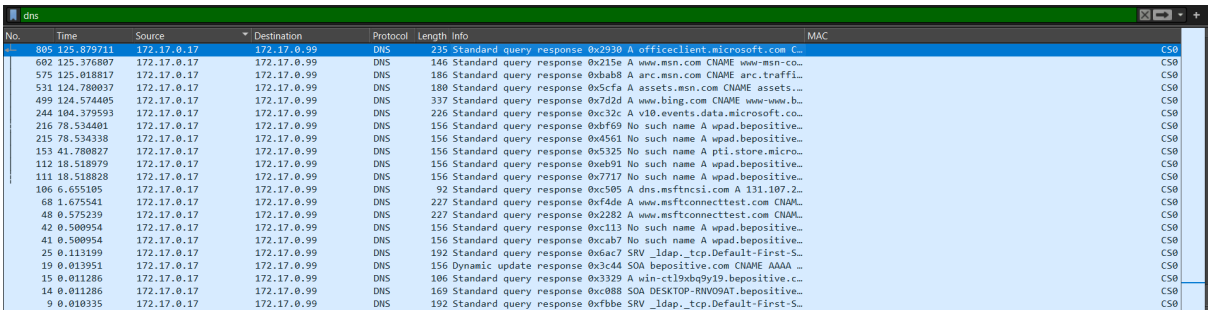
Ces domaines ont été identifiés dans les requêtes DNS générées par la machine analysée.

URL observées

URL

http://79.124.78.197/foots.php

Cet URL a été identifié dans les communications HTTP observées dans la capture.



dns

No.	Time	Source	Destination	Protocol	Length	Info	MAC
805	125.879711	172.17.0.17	172.17.0.99	DNS	235	Standard query response 0x2930 A officeclient.microsoft.com C…	CS0
602	125.376807	172.17.0.17	172.17.0.99	DNS	146	Standard query response 0x215e A www.msn.com CNAME www-msn-co…	CS0
575	125.018817	172.17.0.17	172.17.0.99	DNS	186	Standard query response 0xbab8 A arc.msn.com CNAME arc.traffi…	CS0
531	124.780037	172.17.0.17	172.17.0.99	DNS	180	Standard query response 0x5cfa A assets.msn.com CNAME assets.…	CS0
499	124.574405	172.17.0.17	172.17.0.99	DNS	337	Standard query response 0x7d2d A www.bing.com CNAME www-www.b…	CS0
244	104.379593	172.17.0.17	172.17.0.99	DNS	226	Standard query response 0xc32c A v10.events.data.microsoft.co…	CS0
216	78.534401	172.17.0.17	172.17.0.99	DNS	156	Standard query response 0xbf69 No such name A wpad.bepositive…	CS0
215	78.534338	172.17.0.17	172.17.0.99	DNS	156	Standard query response 0x4561 No such name A wpad.bepositive…	CS0
153	41.780827	172.17.0.17	172.17.0.99	DNS	156	Standard query response 0x5325 No such name A pti.store.micro…	CS0
112	18.518979	172.17.0.17	172.17.0.99	DNS	156	Standard query response 0xeb91 No such name A wpad.bepositive…	CS0
111	18.518828	172.17.0.17	172.17.0.99	DNS	156	Standard query response 0x7717 No such name A wpad.bepositive…	CS0
106	6.655105	172.17.0.17	172.17.0.99	DNS	92	Standard query response 0xc505 A dns.msftncsi.com A 131.107.2…	CS0
68	1.675541	172.17.0.17	172.17.0.99	DNS	227	Standard query response 0xf4de A www.msftconnecttest.com CNAM…	CS0
48	0.575239	172.17.0.17	172.17.0.99	DNS	227	Standard query response 0x2282 A www.msftconnecttest.com CNAM…	CS0
42	0.500954	172.17.0.17	172.17.0.99	DNS	156	Standard query response 0xc113 No such name A wpad.bepositive…	CS0
41	0.500954	172.17.0.17	172.17.0.99	DNS	156	Standard query response 0xcab7 No such name A wpad.bepositive…	CS0
25	0.113199	172.17.0.17	172.17.0.99	DNS	192	Standard query response 0x6ac7 SRV _ldap._tcp.Default-First-S…	CS0
19	0.013951	172.17.0.17	172.17.0.99	DNS	156	Dynamic update response 0x3c44 SOA bepositive.com CNAME AAAA …	CS0
15	0.011286	172.17.0.17	172.17.0.99	DNS	106	Standard query response 0x3329 A win-ctl9xbq9y19.bepositive.c…	CS0
14	0.011286	172.17.0.17	172.17.0.99	DNS	169	Standard query response 0xc088 SOA DESKTOP-RNVO9AT.bepositive…	CS0
9	0.010335	172.17.0.17	172.17.0.99	DNS	192	Standard query response 0xfbbe SRV _ldap._tcp.Default-First-S…	CS0

Analyse de l’activité réseau

L’analyse du trafic permet d’observer le comportement suivant :

La machine **172.17.0.99 (DESKTOP-RNV09AT)** effectue plusieurs requêtes DNS auprès du serveur local **172.17.0.17** afin de résoudre des noms de domaine liés à des services légitimes (**officeclient.microsoft.com**, **bing.com**) mais aussi des requêtes locales intrusives (**wpad.bepositive**).

Après la résolution DNS, la machine établit des connexions réseau avec plusieurs serveurs externes. Si une partie du trafic semble liée à l'activité standard de Windows (Microsoft NCSI, télémétrie), une communication critique a été isolée vers l'adresse **79.124.78.197**.

Les communications observées utilisent principalement les protocoles **DNS** pour la résolution, **UDP/NBNS** pour l'identification sur le réseau local, et surtout le protocole **HTTP** pour l'envoi de données.

L’activité réseau montre un comportement **fortement suspect**, caractérisé par l'exfiltration répétée de données via des requêtes **HTTP POST** vers l'URL **http://79.124.78.197/foots.php**. L'utilisation du port **443** pour du trafic HTTP non chiffré et la répétition de ces envois vers un script PHP externe sont des indicateurs typiques d'une infection par un **malware (type Stealer ou Keylogger)**.

Cette séquence permet d’identifier que la machine **172.17.0.99** est compromise et qu'une phase active d'exfiltration d'informations est en cours vers un serveur de commande et contrôle (C2).

Outils utilisés

Pour réaliser cette analyse, l’outil principal utilisé est :

Wireshark

Cet outil a été sélectionné car il permet :

- l’analyse détaillée des paquets réseau
- l’identification des protocoles utilisés
- la visualisation des communications entre machines
- la recherche d’indicateurs de compromission

Ces fonctionnalités sont adaptées à l’analyse de fichiers PCAP dans le cadre d’une enquête de Digital Forensics.

Conclusion

L’analyse de la capture réseau a permis d’identifier la machine 172.17.0.99 (DESKTOP-RNV09AT) comme étant l’hôte principal impliqué dans les communications observées.

Plusieurs requêtes réseau ont été identifiées vers des services légitimes de télémétrie, mais l'analyse a surtout mis en évidence une communication critique vers l'IP 79.124.78.197. La répétition de requêtes HTTP POST vers la ressource /foots.php sur le port 443 confirme un comportement d'exfiltration de données typique d'un malware actif.

Bien que les requêtes vers Microsoft et Bing soient normales dans un environnement Windows, l'utilisation du protocole HTTP non chiffré pour envoyer des données vers un serveur externe inconnu constitue un Indicateur de Compromission (IoC) majeur.

Dans un contexte réel, il est impératif de :

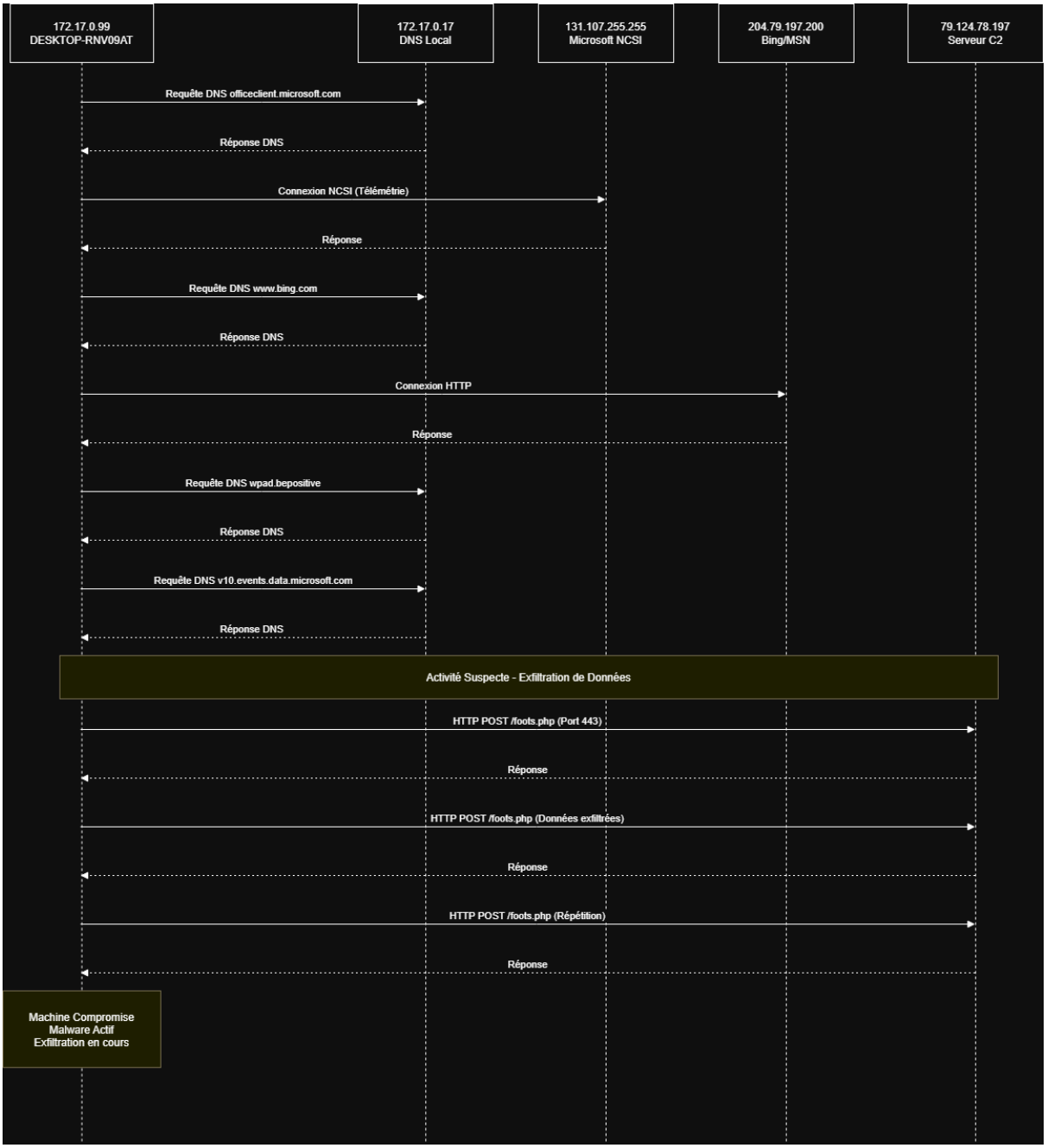
- Isoler immédiatement la machine 172.17.0.99 du réseau pour stopper l'exfiltration en cours.

- Bloquer l'adresse IP 79.124.78.197 au niveau du pare-feu périmétrique.

- Analyser la machine (forensic) pour identifier le processus malveillant à l'origine des requêtes vers le script foots.php.

- Rechercher des fuites de données (mots de passe, fichiers) en inspectant le contenu des flux HTTP (Follow HTTP Stream).

- Renforcer la surveillance sur le domaine local bepositive pour détecter d'éventuels mouvements latéraux.


172.17.0.99
DESKTOP-RNV09AT
172.17.0.17
DNS Local
131.107.255.255
Microsoft NCSI
204.79.197.200
Bing/MSN
79.124.78.197
Serveur C2
Requête DNS officeclient.microsoft.com
Réponse DNS
Connexion NCSI (Télémétrie)
Réponse
Requête DNS www.bing.com
Réponse DNS
Connexion HTTP
Réponse
Requête DNS wpad.bepositive
Réponse DNS
Requête DNS v10.events.data.microsoft.com
Réponse DNS
Activité Suspecte - Exfiltration de Données
HTTP POST /foots.php (Port 443)
Réponse
HTTP POST /foots.php (Données exfiltrées)
Réponse
HTTP POST /foots.php (Répétition)
Réponse
Machine Compromise
Malware Actif
Exfiltration en cours

Job 03

Résumé analytique

Une analyse de la mémoire a été réalisée sur une image de mémoire vive (dump RAM) afin d'identifier d'éventuelles activités malveillantes présentes sur le système.

L'objectif de cette analyse est de détecter des indicateurs de compromission, tels que des processus suspects, des communications réseau inhabituelles ou des traces d'exécution de code malveillant.

L'analyse a été effectuée à l'aide de l'outil :

Volatility 3

Cet outil permet d'examiner les processus actifs, les commandes exécutées, les connexions réseau ainsi que le code présent en mémoire.

Les résultats de l'analyse indiquent la présence d'une activité malveillante sur la machine étudiée.

Résultats principaux

Processus malveillant identifié :

rad5163B.tmp.exe

PID :

1416

Adresse IP suspecte :

172.16.169.164

Type d’activité malveillante :

- exécution d’un programme malveillant depuis le dossier temporaire
- exécution d’un script malveillant
- collecte d’informations système (reconnaissance)
- communication avec un système distant

Informations sur la machine victime

Informations obtenues avec :

python vol.py -f memdump.mem windows.info

Information	Valeur
Système d'exploitation	Windows 7 Service Pack 1
Version du noyau	7601.17514
Architecture	32 bits
Kernel Base	0x82a0f000
DTB (Directory Table Base)	0x185000
Mode mémoire	PAE activé
Nombre de processeurs	1
Répertoire système	C:\Windows
Horodatage système	31 juillet 2019 – 13:45:40 UTC
Type de produit Windows	Workstation (NtProductWinNt)
Fichier de symboles utilisé	ntkrpamp.pdb

L’analyse du dump mémoire indique que :

- Le système analysé fonctionne sous Windows 7 SP1 32 bits.

- Le mode PAE (Physical Address Extension) est activé, permettant à un système 32 bits de gérer plus de mémoire physique.

- La machine possède un seul processeur logique.

- Le système était actif le 31 juillet 2019 à 13:45:40 UTC au moment de l’acquisition mémoire.

Ces informations permettent de confirmer l’environnement du système victime avant de poursuivre l’analyse des processus, connexions réseau et activités suspectes dans la mémoire.

Méthodologie d’analyse

Décrire les étapes utilisées pour l’analyse.

Outils utilisés :

Volatility 3

Méthodes :

- Identification du système
- Analyse des processus
- Analyse des connexions réseau
- Détection d’injection de code
- Recherche d’indicateurs de compromission

Analyse des processus

Commande utilisée :

python vol.py -f memdump.mem windows.pslist

Cette analyse permet de détecter :

- des processus anormaux
- des noms de fichiers suspects
- des processus lancés par des applications inhabituelles

Processus système normaux observés

Plusieurs processus correspondent au fonctionnement normal de Windows :

Processus	Description
System	Processus principal du noyau Windows
smss.exe	Session Manager
csrss.exe	Client Server Runtime Process
wininit.exe	Initialisation des services système
services.exe	Gestionnaire des services Windows
lsass.exe	Service d’authentification Windows
svchost.exe	Hébergement de services Windows
explorer.exe	Interface utilisateur Windows

Ces processus sont attendus dans un environnement Windows 7 et ne présentent pas d’anomalie apparente.

Processus utilisateurs observés

Plusieurs applications utilisateur sont également présentes :

Processus	Description
OUTLOOK.EXE	Client de messagerie Microsoft Outlook
chrome.exe	Navigateur web Google Chrome
WINWORD.EXE	Microsoft Word
notepad.exe	Éditeur de texte Windows

Ces processus indiquent une activité utilisateur normale sur la machine.

Processus suspects identifiés

Un processus particulièrement suspect a été identifié :

Processus	PID	PPID	Heure de création
rfhyMVOQxfc.exe	1292	2728	2019-07-31 12:53:57 UTC
rfhyMVOQxfc.exe	1808	2728	2019-07-31 13:45:17 UTC

Analyse

Ce processus présente plusieurs caractéristiques suspectes :

- Nom aléatoire (rfhyMVOQxfc.exe)
- Exécuté via cscript.exe
- Présence de plusieurs instances
- Activité sur une longue période dans la mémoire

Les noms de fichiers aléatoires sont fréquemment utilisés par des malwares afin d’éviter la détection.

Activités suspectes observées

Plusieurs commandes système ont été exécutées après le lancement de ce processus :

Commande	Utilisation possible
net.exe / net1.exe	Reconnaissance réseau
systeminfo.exe	Collecte d’informations système
reg.exe	Modification du registre
whoami.exe	Identification de l’utilisateur
cmd.exe	Exécution de commandes

Ces outils sont souvent utilisés lors de phases de reconnaissance après compromission.

Interprétation

L'analyse des processus suggère la présence d'un programme malveillant exécuté sur le système, identifié comme :

rfhyMVOQxfc.exe

Ce programme semble avoir lancé plusieurs commandes système afin de :

- collecter des informations sur la machine
- identifier l'utilisateur actif
- interagir avec le système et le registre Windows

Ces comportements sont caractéristiques d'une activité post-exploitation sur une machine compromise.

Analyse de l’arbre des processus

Commande utilisée :

python vol.py -f memdump.mem windows.pstree

Cette commande de Volatility 3 affiche la hiérarchie complète des processus présents en mémoire.

Arbre principal du système

Le système Windows démarre avec une hiérarchie normale :

```
System
 └── smss.exe
     ├── csrss.exe
     └── wininit.exe
         ├── services.exe
         │   ├── svchost.exe
         │   ├── spoolsv.exe
         │   └── SearchIndexer.exe
         ├── lsass.exe
         └── lsm.exe
```

Ces processus font partie du fonctionnement normal de Windows.

Processus utilisateur

La session utilisateur démarre ensuite :

```
winlogon.exe
 └── explorer.exe
     ├── OUTLOOK.EXE
     ├── chrome.exe
     ├── WINWORD.EXE
     └── FTK Imager.exe
```

Ces applications indiquent une activité utilisateur classique :

navigation web

messagerie

utilisation de Microsoft Word

Chaîne d’infection identifiée

L’analyse révèle une chaîne d’exécution suspecte liée à un document Word.

```
explorer.exe
 └── WINWORD.EXE
     └── rad5163B.tmp.exe
         └── cscript.exe
             └── rfhyMVOQxfc.exe
```

Étape 1 — Document Word

WINWORD.EXE

Le programme Microsoft Word ouvre le fichier :

invoice.docm

Les fichiers .docm contiennent des macros, qui peuvent exécuter du code automatiquement.

Étape 2 — Exécutable temporaire

Word lance ensuite :

rad5163B.tmp.exe

Chemin :

C:\Users\johnoc\AppData\Local\Temp\rad5163B.tmp.exe

Les fichiers exécutables dans Temp sont souvent utilisés par des malwares.

Étape 3 — Script malveillant

Ce programme exécute ensuite :

cscript.exe

Commande observée :

cscript "C:\Users\johnoc\AppData\Local\Temp\krtYMkVgyjNdd.vbs"

cscript.exe est l’interpréteur de scripts Windows pour les fichiers VBScript (.vbs).

Étape 4 — Malware final

Le script lance ensuite l'exécutable :

rfhyMVOQxfc.exe

Chemins observés :

C:\Users\johnoc\AppData\Local\Temp\rad0C636.tmp\rfhyMVOQxfc.exe
C:\Users\johnoc\AppData\Local\Temp\rad41020.tmp\rfhyMVOQxfc.exe

Le nom du fichier semble aléatoire, ce qui est une technique courante utilisée par les malwares pour éviter la détection.

Activité post-infection

Le processus rad5163B.tmp.exe lance plusieurs commandes système :

Commande	Objectif probable
net.exe / net1.exe	collecte d'informations réseau
systeminfo.exe	récupération d'informations système
reg.exe	modification du registre
cmd.exe	exécution de commandes
whoami.exe	identification de l'utilisateur

Ces outils sont souvent utilisés lors d'une phase de reconnaissance après compromission.

Interprétation

L’analyse de l’arbre des processus montre un scénario d’infection probable :

L’utilisateur ouvre invoice.docm dans Word

La macro du document lance rad5163B.tmp.exe

Ce programme exécute un script VBScript

Le script installe et exécute le malware rfhyMVOQxfc.exe

Le malware collecte des informations système

Ce comportement correspond à une attaque par document Office malveillant avec macro.

Analyse des connexions réseau

Commande utilisée :

python vol.py -f memdump.mem windows.netscan

Cette commande permet d'identifier :

- les ports ouverts
- les connexions actives
- les adresses IP distantes
- les processus responsables des communications
- Informations réseau de la machine

Adresse IP locale observée :

172.16.169.167

Cette adresse correspond à une adresse privée interne, utilisée dans un réseau local.

Ports système normaux

Plusieurs ports système Windows sont ouverts et correspondent à des services normaux :

Port	Service	Processus
135	RPC	svchost.exe
139	NetBIOS	System
445	SMB	System
49152-49157	Ports dynamiques Windows	svchost.exe / services.exe
5355	LLMNR	svchost.exe
3702	WS-Discovery	svchost.exe

Ces services sont attendus sur un système Windows et ne sont pas considérés comme suspects.

Connexion externe légitime

Une connexion réseau légitime est observée :

Processus	IP distante	Port	Service
OUTLOOK.EXE	66.102.1.108	993	IMAP sécurisé

Port : 993

Ce port correspond au protocole IMAPS, utilisé pour récupérer des emails de manière sécurisée.

Connexions suspectes identifiées

Plusieurs connexions réseau suspectes sont observées vers la même machine distante.

Processus	IP locale	IP distante	Port distant	État
rad5163B.tmp.exe	172.16.169.167	172.16.169.164	4444	ESTABLISHED
rfhyMVOQxfc.exe	172.16.169.167	172.16.169.164	4444	ESTABLISHED
rfhyMVOQxfc.exe	172.16.169.167	172.16.169.164	4444	CLOSED
bVwHCYX.exe	172.16.169.167	172.16.169.164	4444	CLOSED

Adresse distante :

172.16.169.164

Port utilisé : 4444

Interprétation du port 4444

Le port 4444 est fréquemment utilisé par des backdoors et outils d'accès distant dans les environnements de test de sécurité.

Dans ce cas, plusieurs processus malveillants communiquent avec cette même adresse :

rad5163B.tmp.exe
rfhyMVOQxfc.exe
bVwHCYX.exe

Ces noms de fichiers aléatoires sont caractéristiques des malwares.

Activité suspecte observée

Les observations montrent :

- plusieurs connexions vers la même machine
- un port typique de contrôle à distance
- des exécutables au nom aléatoire
- une connexion active (ESTABLISHED)

Cela indique probablement la présence d’un serveur de commande et contrôle (C2) sur l’hôte :

172.16.169.164

Conclusion

L’analyse réseau révèle que la machine compromise communique avec un système distant sur le port 4444.

Cette communication est réalisée par plusieurs processus malveillants :

rad5163B.tmp.exe
rfhyMVOQxfc.exe
bVwHCYX.exe

Ces connexions suggèrent qu’un attaquant dispose probablement d’un accès distant à la machine compromise via un canal de commande et contrôle.

Détection de code malveillant

Commande utilisée :

python vol.py -f memdump.mem windows.malfind

Ce plugin permet de détecter :

- du code injecté
- des payloads en mémoire
- des exécutables chargés sans fichier sur disque
- des shellcodes

Il se base notamment sur les pages mémoire ayant les permissions :

PAGE_EXECUTE_READWRITE

Ces permissions sont souvent utilisées par les malwares pour exécuter du code injecté.

Processus suspects détectés

L’analyse révèle plusieurs processus contenant du code exécutable suspect.

Processus malveillant principal

Processus identifié :

rad5163B.tmp.exe

Informations :

PID	Processus	Type
1416	rad5163B.tmp.exe	exécutable suspect

Plusieurs segments mémoire contiennent un header MZ :

MZ

Le header MZ correspond à la signature d’un fichier exécutable Windows.

La présence de cet en-tête dans la mémoire indique qu’un exécutable est chargé directement en mémoire, ce qui est typique des techniques de :

process injection

reflective loading

fileless malware

Shellcode observé

Le début du code mémoire contient une structure typique de shellcode Windows :

fc e8 82 00 00 00 60 89 e5 31 c0 64 8b 50 30

Ce type de shellcode est souvent utilisé pour :

parcourir le Process Environment Block (PEB)

localiser les API Windows

charger dynamiquement des fonctions système

Cela confirme que ce processus exécute du code malveillant injecté.

Deuxième processus malveillant

Un autre processus suspect est identifié :

rfhyMVOQxfc.exe

Informations :

PID	Processus
1808	rfhyMVOQxfc.exe

Ce processus contient également :

- du shellcode
- des pages exécutables en mémoire
- des permissions **PAGE_EXECUTE_READWRITE**

Le shellcode observé est très similaire à celui du premier processus, ce qui indique probablement le même malware ou la même famille d'attaque.

Injection dans des processus légitimes

Du code exécutable suspect est également observé dans des processus Windows légitimes :

Processus	PID
svchost.exe	2896
explorer.exe	588
OUTLOOK.EXE	3476
WINWORD.EXE	3544

Ces processus contiennent des pages mémoire avec la permission :

PAGE_EXECUTE_READWRITE

Cela peut indiquer une injection de code dans des processus système afin de masquer l'activité malveillante.

Interprétation de l'attaque

Les éléments observés indiquent une attaque utilisant :

- du shellcode
- du chargement d'exécutables en mémoire
- de l'injection dans des processus légitimes

Ces techniques sont typiques des malwares avancés et des backdoors.

Le processus principal identifié est :

rad5163B.tmp.exe

Ce processus semble être le payload principal du malware.

Conclusion

L’analyse du plugin malfind révèle la présence de plusieurs exécutables malveillants exécutés directement en mémoire.

Les processus suivants sont identifiés comme suspects :

rad5163B.tmp.exe
rfhyMVOQxfc.exe

Ces programmes utilisent du shellcode et des exécutables chargés en mémoire, ce qui indique une compromission active de la machine.:

Commandes exécutées

L'analyse de la mémoire permet d'identifier plusieurs commandes exécutées sur la machine compromise.
Ces informations ont été obtenues à partir du plugin cmdline, qui affiche les arguments utilisés lors du lancement des processus.

Commande utilisée :

python vol.py -f memdump.mem windows.cmdline

Cette analyse permet d'identifier les outils utilisés par l'attaquant après la compromission.

Ouverture du document malveillant

Le processus suivant indique l'ouverture d'un document Word contenant des macros :

Processus Commande
WINWORD.EXE "C:\Program Files\Microsoft Office\Office15\WINWORD.EXE" /n "C:\Users\johnoc\Downloads\invoice\invoice.docm"

Fichier ouvert :

invoice.docm

L'extension .docm correspond à un document Microsoft Word contenant des macros. Ces fichiers sont fréquemment utilisés pour distribuer des malwares via des campagnes de phishing.

Exécution du payload malveillant

Deux exécutables suspects sont observés dans le répertoire temporaire de l'utilisateur.

PID	Processus	Chemin
1416	rad5163B.tmp.exe	C:\Users\johnoc\AppData\Local\Temp\rad5163B.tmp.exe
1808	rfhyMVOQxfc.exe	C:\Users\johnoc\AppData\Local\Temp\rad41020.tmp\rfhyMVOQxfc.exe

Le fait que ces fichiers soient exécutés depuis le dossier Temp est un comportement typique des malwares.

Exécution d'un script malveillant

Un script VBScript est également exécuté :

Processus	Commande
cscript.exe	cscript "C:\Users\johnoc\AppData\Local\Temp\krtYMkVgyjNdd.vbs"

Les scripts VBScript sont souvent utilisés pour :

- télécharger des payloads
- exécuter des commandes système
- installer des backdoors

Commandes de reconnaissance système

Plusieurs commandes système ont été exécutées, ce qui indique une phase de reconnaissance par l'attaquant.

Commande	Objectif
whoami.exe	identifier l'utilisateur courant
systeminfo.exe	récupérer les informations du système
net.exe / net1.exe	obtenir des informations réseau ou utilisateurs
reg.exe	lire ou modifier le registre Windows
NETSTAT.EXE	afficher les connexions réseau

Ces commandes sont typiquement utilisées après une compromission pour collecter des informations sur la machine et le réseau.

Interprétation de l’activité observée

Les éléments observés suggèrent le scénario suivant :

L’utilisateur ouvre un document Word malveillant :

invoice.docm

Les macros du document exécutent un script :

krtYMkVgyjNdd.vbs

Le script déploie des exécutables malveillants dans le dossier temporaire :

rad5163B.tmp.exe
rfhyMVOQxfc.exe

L’attaquant exécute plusieurs commandes système afin de collecter des informations sur la machine compromise.

Conclusion

L’analyse des commandes exécutées montre que la compromission de la machine semble avoir commencé par l’ouverture d’un document Word contenant des macros malveillantes.
Ces macros ont ensuite exécuté un script VBScript permettant d’installer et d’exécuter plusieurs programmes malveillants, suivis d’une phase de reconnaissance du système par l’attaquant.

Indicateurs de compromission (IOC)

Liste des IOC identifiés :

Processus malveillants

Nom :

rad5163B.tmp.exe

PID :

1416

Autre processus suspect :

Nom :

rfhyMVOQxfc.exe

PID :

1808

Adresses IP suspectes

172.16.169.164

Chemins de fichiers

C:\Users\johnoc\AppData\Local\Temp\rad5163B.tmp.exe
C:\Users\johnoc\AppData\Local\Temp\rad41020.tmp\rfhyMVOQxfc.exe
C:\Users\johnoc\AppData\Local\Temp\krtYMkVgyjNdd.vbs
C:\Users\johnoc\Downloads\invoice\invoice.docm

Domaines observés

wiresharkworkshop.online
wireshark-ws-dc.wiresharkworkshop.online
wpad.wiresharkworkshop.online

Conclusion

L'analyse de la mémoire de la machine a permis d'identifier plusieurs éléments indiquant une compromission du système.

L'investigation montre que l'utilisateur a ouvert un document Microsoft Word contenant des macros malveillantes :

C:\Users\johnoc\Downloads\invoice\invoice.docm

Ce document a probablement déclenché l'exécution d'un script VBScript :

C:\Users\johnoc\AppData\Local\Temp\krtYMkVgyjNdd.vbs

Ce script a ensuite permis le déploiement et l'exécution de programmes malveillants dans le dossier temporaire de l'utilisateur.

Les processus suspects suivants ont été identifiés :

rad5163B.tmp.exe
rfhyMVOQxfc.exe

Ces exécutables sont lancés depuis le répertoire **Temp**, ce qui constitue un comportement typique des malwares.

L'analyse de la mémoire a également révélé la présence de code exécutable suspect, indiquant une possible **injection de code en mémoire**.

Par ailleurs, plusieurs commandes système ont été exécutées, notamment :

whoami
systeminfo
net
reg
netstat

Ces commandes sont souvent utilisées par un attaquant pour effectuer une phase de **reconnaissance du système** après une compromission.

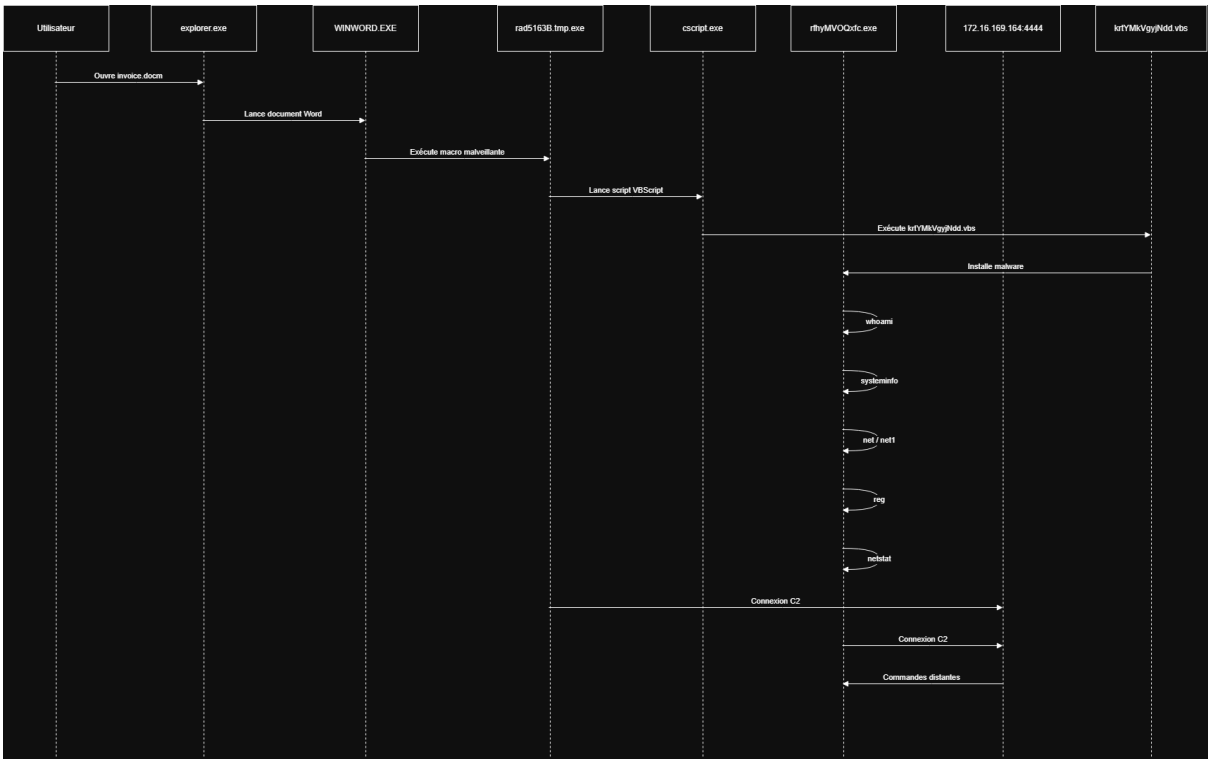
L'analyse réseau indique également que la machine compromise communique avec une adresse IP distante :

172.16.169.164

Impact potentiel

Les éléments observés indiquent plusieurs impacts possibles :

- compromission du système
- exécution de code malveillant
- collecte d'informations sur la machine compromise
- communication avec un serveur distant pouvant correspondre à un serveur de commande et contrôle



Pour aller plus loin (Root.me)

5 Points

Tu peux regarder ce que tu veux, mais cette clé est vide...

Auteur	Niveau	Validations	Note
Manah, 24 mai 2023		13658 Challengeurs 4%	940 votes J'aime Je n'aime pas

Énoncé

Votre cousin a trouvé une clé USB à la bibliothèque ce matin. Il n'est pas très doué avec les ordinateurs, alors il compte sur vous pour retrouver le propriétaire de cette clé !

Le flag est l'identité du propriétaire sous la forme `prénom_nom`

sha256sum : cd9f4ada5e2a97ec6def655547652471276 0e3d8ee99c26ec2f11682a1194778

Objectif

Une clé USB a été trouvée et l'objectif est d'identifier son propriétaire.
Le flag doit être donné sous la forme :

prenom_nom

Pour résoudre ce challenge, une analyse des données présentes sur la clé USB est réalisée afin de rechercher des informations permettant d'identifier son propriétaire.

Outil utilisé

L'outil utilisé est **Strings**, un programme permettant d'extraire les chaînes de caractères lisibles présentes dans un fichier binaire.

Cet outil fait partie de la **Sysinternals Suite** développée par **Microsoft**.

Il est particulièrement utile en analyse forensique pour retrouver :

- des noms
- des chemins de fichiers
- des métadonnées
- des fragments de texte présents dans des fichiers binaires

Installation de l'outil

L'outil est téléchargé depuis la page officielle de Microsoft :

https://learn.microsoft.com/sysinternals/downloads/strings

Après téléchargement, l'archive **Strings.zip** est extraite.
Elle contient les fichiers suivants :

strings.exe

strings64.exe

Eula.txt

Dans ce cas, l'ordinateur étant en architecture 64 bits, l'exécutable utilisé est :

strings64.exe

Ce fichier est placé dans le dossier du challenge contenant le fichier à analyser.

Exemple de structure :

```
challenge/
├─ ch39
└─ strings64.exe
```

Analyse du fichier

Une fois dans le dossier contenant les fichiers, un terminal **Windows PowerShell** est ouvert.

La commande suivante est utilisée pour extraire les chaînes de caractères du fichier :

.\strings64.exe ch39

Cette commande affiche toutes les chaînes de texte lisibles présentes dans le fichier.

```
<dc:creator>
 <rdf:Seq>
  <rdf:li>Javier Turcot</rdf:li>
 </rdf:Seq>
</dc:creator>
```

Dans la sortie obtenue, la ligne suivante apparaît :

Javier Turcot

Cette information correspond probablement au créateur d'un fichier présent sur la clé USB.

Interprétation

Le nom **Javier Turcot** est identifié comme étant le propriétaire probable de la clé USB.

Le challenge demande un flag au format :

prenom_nom

Le flag devient donc :

javier_turcot

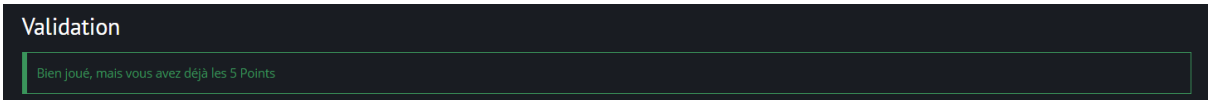
Conclusion

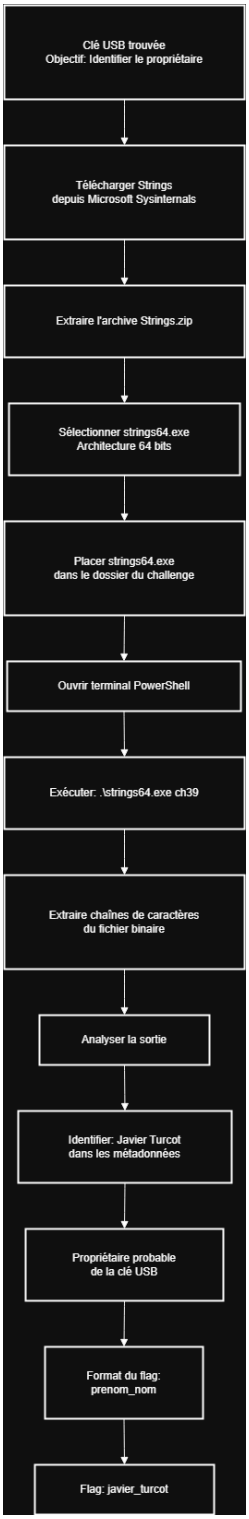
L’analyse de la clé USB a été réalisée en utilisant l’outil **Strings**, qui permet d’extraire les chaînes de caractères présentes dans un fichier.

Cette méthode a permis d’identifier dans les métadonnées le nom **Javier Turcot**, qui correspond au propriétaire probable de la clé USB.

Le flag du challenge est donc :

javier_turcot




Clé USB trouvée
Objectif: Identifier le propriétaire
Télécharger Strings
depuis Microsoft Sysinternals
Extraire l'archive Strings.zip
Sélectionner strings64.exe
Architecture 64 bits
Placer strings64.exe
dans le dossier du challenge
Ouvrir terminal PowerShell
Exécuter: .\strings64.exe ch39
Extraire chaînes de caractères
du fichier binaire
Analyser la sortie
Identifier: Javier Turcot
dans les métadonnées
Propriétaire probable
de la clé USB
Format du flag:
prenom_nom
Flag: javier_turcot